

CHAINDROP NODE-TO- BUN EXECUTION

Campaign hunt for the source-observed
setup.mjs dropper launching a Bun payload
from temporary or node_modules paths.

HUNTING QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

DeviceProcessEvents

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

06 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceProcessEvents

ATT&CK

T1059.007

Evidence-led dossier. Query status remains an untested
implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER

01

EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Retain the parent command and Bun execution context.

Microsoft and Elastic independently observed CHAINDROP executing through node setup.mjs before launching a Bun payload. Microsoft published the exact parent command plus the bun-dl- or node_modules execution conditions used in this hunt.

OPERATIONAL VALUE

Direct visibility before credential theft and worm propagation.

The child process event creates an investigable endpoint pivot on developer workstations and build runners without depending on rotating C2 domains or package hashes.

8.8

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Hunting

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- A malicious npm preinstall hook launches setup.mjs.
- The dropper downloads Bun when needed and uses it to execute the payload.
- Microsoft published a DeviceProcessEvents hunt for the Node-to-Bun relationship.

ANALYTICAL ASSESSMENT

What the evidence supports

- Parent command plus child runtime context is stronger than Node or Bun alone.
- The pattern is useful for scoping endpoints and CI runners before downstream impact is confirmed.
- A match is a campaign hunt lead, not proof of credential theft or propagation.

DETECTION ASSUMPTIONS

What must be validated

- MDE captures both process and initiating-process command lines.
- Command lines preserve the source-observed spacing and relative setup.mjs invocation.
- Legitimate builds do not frequently reproduce the complete relationship.

Confidence boundary

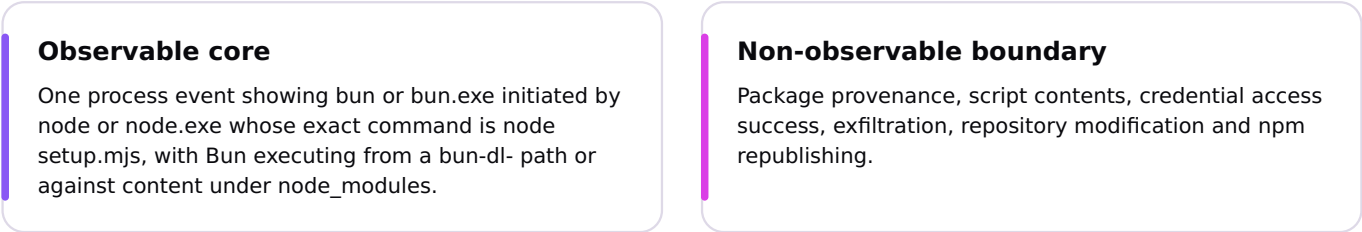
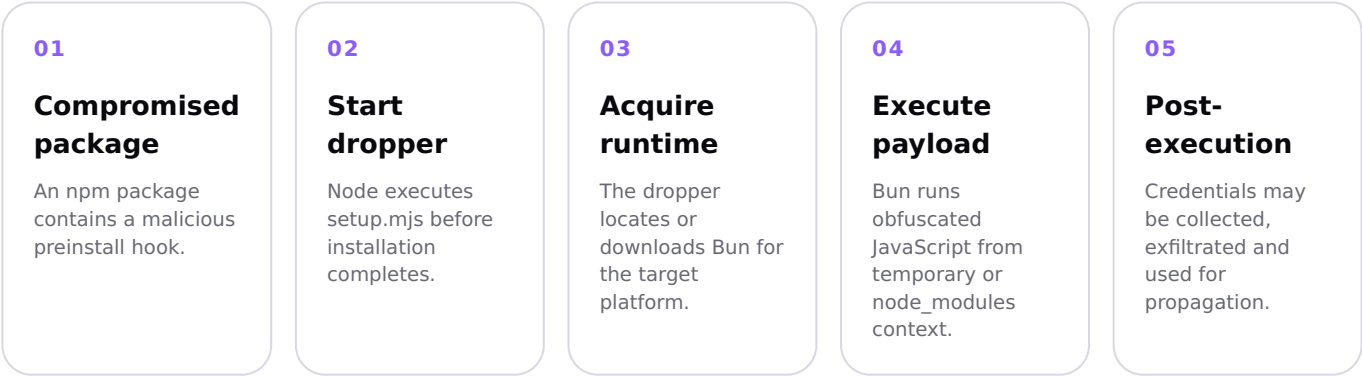
setup.mjs and Bun are legitimate. The exact filenames, temporary path and command shape are mutable, so the logic remains a campaign-specific hunt until tenant prevalence and variants are measured.



THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

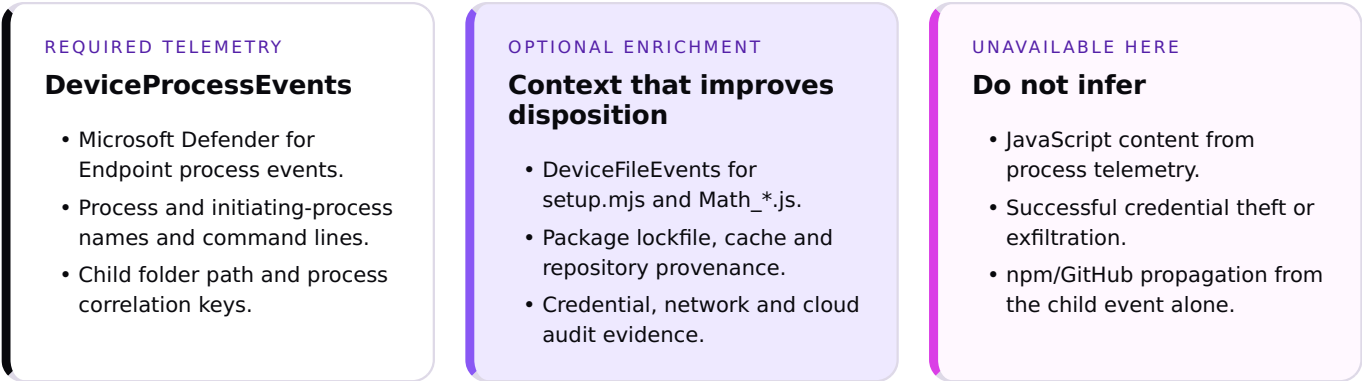
ATTACK FLOW



DETECTION HYPOTHESIS

The dropper-to-runtime handoff should remain visible in process telemetry.

If CHAINDROP executes through the documented preinstall path, DeviceProcessEvents should show node setup.mjs initiating Bun from a bun-dl- directory or with node_modules in the child command line. Legitimate activity can be separated through package provenance, repository history, script hashes, build ownership and follow-on behavior.





TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR · DeviceProcessEvents

Contains process creation events with child and initiating process names, paths, command lines, hashes, accounts, device and unique process identifiers.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

The table can establish the process relationship and command context. It cannot establish that setup.mjs or the Bun payload is malicious without file and provenance evidence.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Process event	DeviceProcessEvents	Primary Node-to-Bun evidence.	REQUIRED
Child runtime	FileName, FolderPath	Bun identity and temporary-path context.	REQUIRED
Child command	ProcessCommandLine	node_modules execution context.	REQUIRED
Parent	InitiatingProcessFileName	Node identity.	REQUIRED
Parent command	InitiatingProcessCommandLi ne	Exact setup.mjs invocation.	REQUIRED
Process keys	ProcessUniqueId, InitiatingProcessUniqueId	Investigative correlation.	REQUIRED
Device/event	DeviceId, DeviceName, Timestamp, ReportId	Endpoint and raw-event pivot.	REQUIRED

Data quality requirements

- Confirm full command-line collection on developer and CI assets.
- Validate Linux, macOS and Windows path behavior.
- Preserve raw events and both process keys.
- Inventory legitimate Node-to-Bun build workflows.

Known failure conditions

- Command lines are truncated or normalized differently.
- The dropper uses a full path or changed script name.
- Bun is invoked without the published path indicators.
- Developer or CI assets are not onboarded.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

HUNTING QUERY

DETECTION OBJECTIVE

Find the documented Node-to-Bun handoff.

Select Bun processes only when the source-published Node parent command and temporary or node_modules execution context are present.

ANALYTICAL LOGIC

Direct filters and investigable output.

Four direct predicates; no IOC list, join, sequence, threshold, aggregation, rarity or automatic verdict.

KQL · UNTESTED HUNT

```
// CHAINDROP - node setup.mjs launches Bun payload
// Classification: Hunting query - Untested implementation sketch
// Confidence: Medium
// Primary platform: Microsoft Defender XDR
// Telemetry: Microsoft Defender for Endpoint DeviceProcessEvents
//
// Microsoft and Elastic observed the preinstall dropper setup.mjs launching Bun.
// Microsoft published the parent command and Bun path/command-line conditions below.
// A match is not proof of a compromised npm package: validate package provenance,
// repository changes, script hashes, signer/origin, credentials and follow-on activity.

DeviceProcessEvents
| where InitiatingProcessFileName in~ ("node", "node.exe")
| where InitiatingProcessCommandLine in~ ("node setup.mjs", "node setup.mjs")
| where FileName in~ ("bun", "bun.exe")
| where FolderPath contains "bun-dl-" or ProcessCommandLine has "node_modules"
| project Timestamp,
    DeviceId,
    DeviceName,
    AccountName,
    FileName,
    FolderPath,
    ProcessCommandLine,
    ProcessUniqueId,
    InitiatingProcessFileName,
    InitiatingProcessFolderPath,
    InitiatingProcessCommandLine,
    InitiatingProcessUniqueId,
    SHA1,
    ReportId
| order by Timestamp desc
```

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested hunt	None	None	DeviceId + ProcessUniqueId	Manual triage

What a match means

The endpoint recorded the published CHAINDROP dropper-to-runtime relationship and requires package, file and repository validation.

What a match does not prove

Malicious script contents, credential theft, exfiltration, repository persistence, package publication or attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the raw event.
Verify parent and child names, commands, paths, account, device and process keys.
- 02

Collect the scripts.
Acquire setup.mjs and the Bun-executed JavaScript; calculate hashes and inspect origin.
- 03

Validate package provenance.
Review lockfile, package version, registry metadata, cache and release history.
- 04

Inspect repository state.
Check for unexpected .claude and .vscode hooks, commits and branch changes.
- 05

Scope credentials and follow-on.
Review npm, GitHub, cloud and secret-store access; rotate from a clean host if exposure is credible.

Escalation gate

Escalate when the relationship is unowned and corroborated by affected package versions, malicious script hashes, unauthorized repository hooks, credential access or suspicious network activity.

Primary benign overlap

Legitimate projects may use setup.mjs and Bun, including package installation and build tooling. Tune with approved repository/package provenance and stable build paths, never by runtime name alone.

INVESTIGATION PIVOTS

Host
Developer/runner role, coverage and neighboring alerts.

Parent
Node path, command and package ancestry.

Child
Bun path, command, hash and descendants.

Files
setup.mjs, Math_*.js, caches and lockfiles.

Repository
Commits, hooks, branches and provenance.

Identity
npm, GitHub, cloud and secret-store activity.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Legitimate Bun bootstrap	A project may download or invoke Bun during setup.	Require approved repository, package owner and known script hash.
CI build workflow	Build jobs may run Node setup scripts from node_modules.	Validate pipeline definition, runner identity and release provenance.
Security testing	May reproduce the published chain.	Scope to approved assets, repository and test window.

Baseline plan

- Run across 30-90 days.
- Inspect every raw match.
- Separate developer workstations and CI runners.
- Record approved repository and package provenance.

Validation procedure

- Replay a benign equivalent chain on each supported OS.
- Confirm exact command-line and path semantics.
- Compare events with endpoint ground truth.
- Measure legitimate variants and missed attack variants.

TEST CASES

CASE	EXPECTED RESULT
Controlled Node setup.mjs spawning Bun under bun-dl-	Expected match with complete process fields.
Node setup.mjs spawning another runtime	No match.
Bun launched directly by a user	No match.
Node full-path setup script variant	Expected miss; document normalization gap.

Hunting Initial query	Candidate Current status	Production Measured precision	Optimized Stable feedback
---------------------------------	------------------------------------	---	-------------------------------------

Success

Controlled replay matches with complete fields and residual volume is low and explainable.

Rejection

Legitimate builds frequently reproduce the full relationship without durable provenance-based separation.

Failure

Required process or initiating-process fields are missing or truncated.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1059.007	Command and Scripting Interpreter: JavaScript	Directly covers JavaScript execution through Node and Bun in the source-observed package-install chain.

Detection coverage summary

Strong for the exact setup.mjs-to-Bun relationship; weak for renamed loaders, full-path commands, alternative runtimes or telemetry gaps.

Residual risk

Campaign artifacts can change, while package compromise, secret theft and propagation require repository, identity and network evidence.

ANALYST CONCLUSION

A high-value supply-chain hunt, not a standalone compromise verdict.

Independent primary research and a Microsoft-published hunting pattern support a selective Defender XDR implementation. It remains untested until cross-platform replay and tenant baseline confirm complete command lines and manageable legitimate Node-to-Bun overlap.

REFERENCES

- Microsoft Security Research, "ChainDrop supply chain compromise: Anatomy of a self-propagating worm," 4 August 2026. <https://www.microsoft.com/en-us/security/blog/2026/08/04/chaindrop-supply-chain-compromise-anatomy-self-propagating-worm/>
- Elastic Security Labs, "Shai-Hulud strikes again: CHAINDROP worm hits 400+ npm packages," 6 August 2026. <https://www.elastic.co/security-labs/shai-hulud-chaindrop-npm-supply-chain>
- Microsoft Learn, "DeviceProcessEvents table," accessed 6 August 2026. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>
- MITRE ATT&CK, T1059.007. <https://attack.mitre.org/techniques/T1059/007/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	06 August 2026	Hunting	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.